

# ICEDID

## Malware Intelligence Investigation Report

*CyberDefenders Training Lab*

| Report detail       | Value                                             |
|---------------------|---------------------------------------------------|
| Prepared by         | Alaa Zahra                                        |
| Investigation focus | Malware analysis and threat intelligence          |
| Evidence sources    | VirusTotal, Malpedia, WHOIS data, sandbox reports |
| Classification      | Educational and authorized lab analysis           |

### Purpose

Document the evidence-led investigation of a malicious Excel sample, its second-stage payload delivery, related infrastructure, threat-cluster association, and execution behavior.

## Executive Summary

The investigation identified a malicious macro-enabled Excel workbook associated with IcedID. Threat-intelligence and sandbox evidence showed that the document attempted to retrieve an additional object named 3003.gif from five domains. Domain registration data linked the relevant .com infrastructure to NameCheap, while Malpedia associated the IcedID family with the GOLD CABIN threat cluster. Behavioral analysis showed that Excel invoked the URLDownloadToFile API family; the execution-specific function used to fetch the additional payload was URLDownloadToFileA.

The evidence supports a downloader-style infection chain in which a user opens a weaponized Office document, embedded logic initiates outbound web activity, and a disguised second-stage payload is written to the endpoint. The report recommends hunting across email, endpoint, DNS, proxy, and file telemetry rather than relying on a single indicator.

## Scope and Objectives

| Objective            | Investigation question                                            |
|----------------------|-------------------------------------------------------------------|
| Validate the sample  | Which file is associated with the supplied hash?                  |
| Identify the payload | Which additional file was deployed?                               |
| Map infrastructure   | How many domains hosted the payload and which registrar was used? |
| Assess attribution   | Which threat cluster is associated with the malware family?       |
| Confirm behavior     | Which Windows function fetched the additional payload?            |

## Evidence Handling and Safety

The investigation used the supplied hash as the initial pivot and reviewed public intelligence and historical sandbox results. The malware was not executed on the analyst's host. Historical domains and IP addresses were treated as time-sensitive indicators because infrastructure ownership and reputation can change.

## Methodology

| Stage | Action                                 | Reason                                       |
|-------|----------------------------------------|----------------------------------------------|
| 1     | Search the supplied hash in VirusTotal | Resolve the sample and validate its metadata |

|   |                                 |                                                     |
|---|---------------------------------|-----------------------------------------------------|
| 2 | Inspect Details and Relations   | Identify filenames, URLs, payloads, and domains     |
| 3 | Review WHOIS information        | Determine the domain registrar                      |
| 4 | Cross-reference Malpedia        | Assess malware-family and threat-actor associations |
| 5 | Review multiple sandbox reports | Confirm execution behavior and download APIs        |

## Detailed Findings

### 1. Sample Validation and Original Filename

VirusTotal metadata identified the submitted object as a malicious macro-enabled Microsoft Excel workbook and listed its original filename.

The screenshot displays the VirusTotal analysis interface for a file with SHA-256 hash `d86405130184186154daa4a5132dd1364ab05d1f14034c7f0a0cda690a91116d`. The file is identified as an "Office Open XML Spreadsheet" (document, msoffice, spreadsheet, excel, .xlsx). The History section shows the file was created on 2006-09-16 and first submitted on 2021-03-31. The Names section lists several filenames, including `document-1982481273.xlsm`. The Bundle Info section shows the file contains 24 files and has an uncompressed size of 983.26 KB.

Figure 1. VirusTotal metadata showing the sample type and original filename.

**Finding:** The file associated with the supplied hash was `document-1982481273.xlsm`.

The `.xlsm` extension means that the workbook can contain VBA macros. This capability is relevant to the infection chain, but the extension alone is not evidence that every `.xlsm` file is malicious.

## 2. Additional Payload Identification

The Relations view exposed several URLs connected to the document. The same filename appeared at the end of multiple download paths.

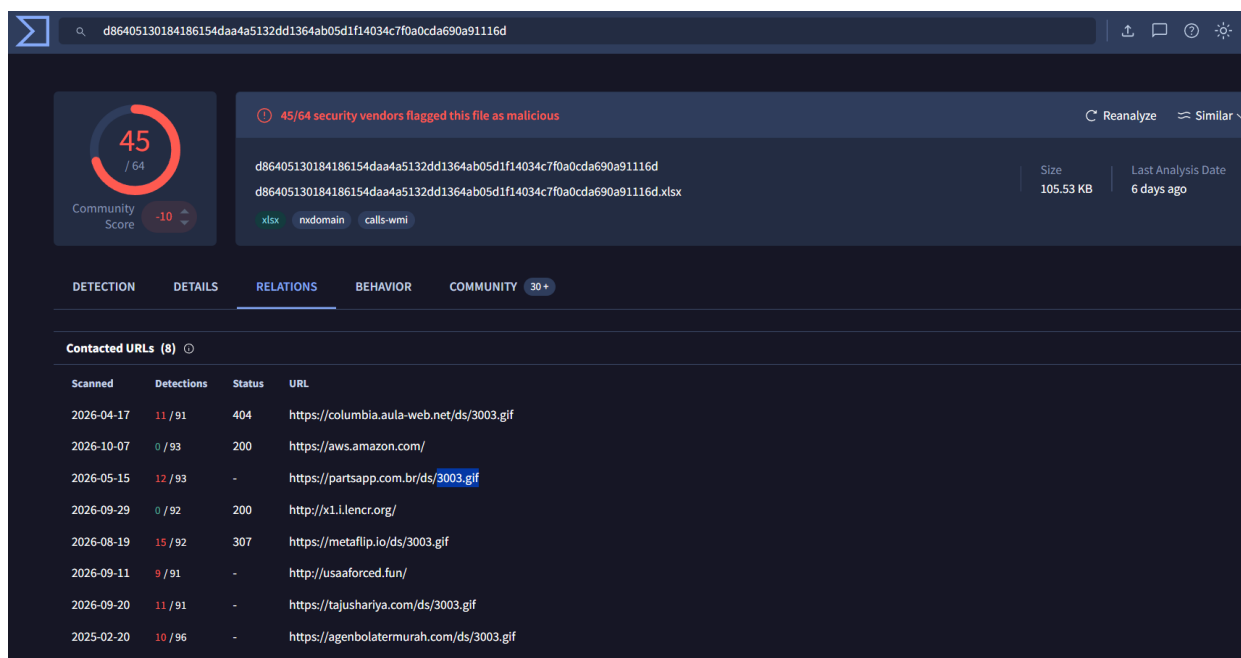


Figure 2. Connected URLs showing repeated delivery of 3003.gif.

**Finding:** The deployed payload filename was 3003.gif.

The apparent image extension should not be trusted as a content guarantee. Malware frequently uses benign-looking extensions to disguise executable or library content.

## 3. Payload Hosting Infrastructure

The URL and domain relations showed multiple delivery locations for the same payload. Counting unique domains, rather than URL rows, avoided double-counting repeated paths.

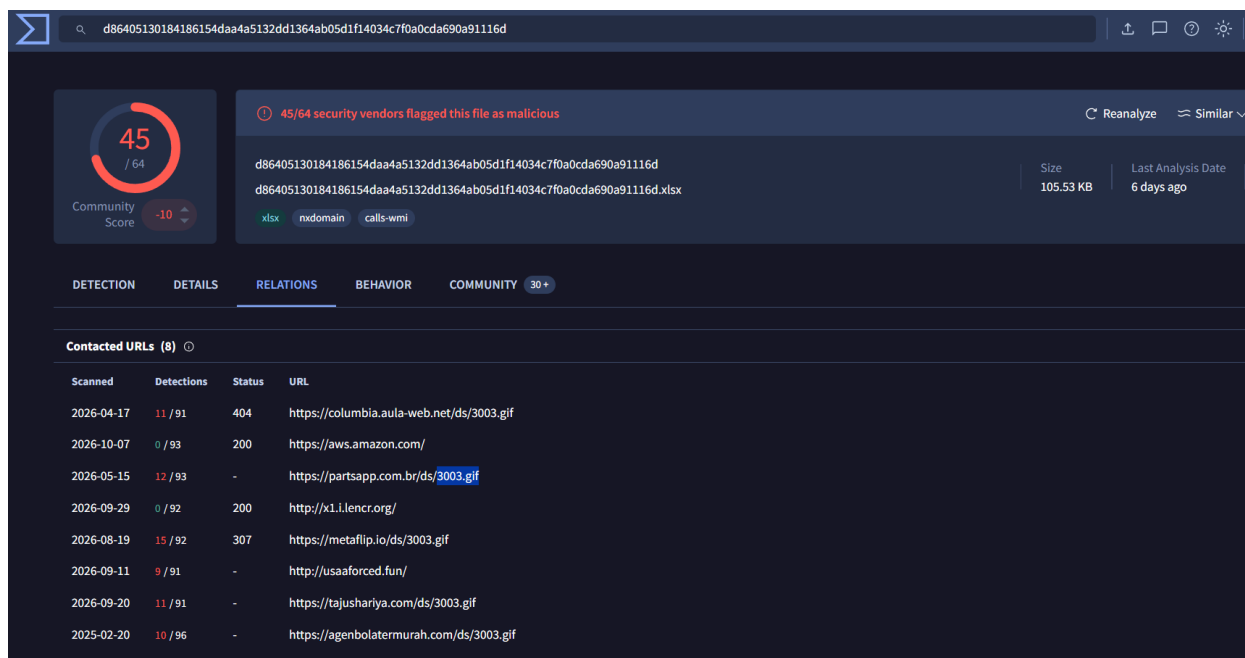


Figure 3. VirusTotal domain relations used to count the payload-hosting infrastructure.

**Finding:** Five distinct domains were used as candidate download locations.

Multiple hosts add resilience to a malware campaign because the payload can remain reachable when individual domains are blocked or taken offline.

## 4. Registrar Identification

Registration information for the relevant .com domain was reviewed to identify the registrar named in the lab question.

2026-09-20 11 / 91 - https://tajushariya.com/ds/3003.gif

2025-02-20 10 / 96 - https://agenbolatermurah.com/ds/3003.gif

CONTACTED DOMAINS (15)

| Domain                         | Detections | Created    | Registrar        |
|--------------------------------|------------|------------|------------------|
| 77980.bodis.com                | 4 / 92     | 2005-12-13 | -                |
| agenbolatermurah.com           | 5 / 92     | 2026-04-26 | -                |
| amazon.com                     | 0 / 92     | 1994-11-01 | MarkMonitor Inc. |
| aula-web.net                   | 0 / 92     | 2013-01-21 | -                |
| aws.amazon.com                 | 0 / 92     | 1994-11-01 | MarkMonitor Inc. |
| bg.microsoft.map.fastly.net    | 0 / 92     | -          | -                |
| columbia.aula-web.net          | 10 / 92    | 2013-01-21 | -                |
| edge.ds-c7110-microsoft.glo... | 0 / 92     | 2015-08-27 | GoDaddy.com, LLC |
| i.lencr.org                    | 0 / 92     | 2020-06-29 | Cloudflare, Inc. |
| metaflip.io                    | 13 / 92    | 2025-09-30 | -                |
| ocsp.comodoca.com              | 0 / 92     | 2002-11-13 | -                |
| partsapp.com.br                | 8 / 92     | -          | -                |
| tajushariya.com                | 10 / 92    | 2022-07-30 | NameCheap, Inc.  |
| usaaforded.fun                 | 9 / 92     | 2021-03-25 | Porkbun, LLC     |
| x1.lencr.org                   | 0 / 92     | 2020-06-29 | Cloudflare, Inc. |

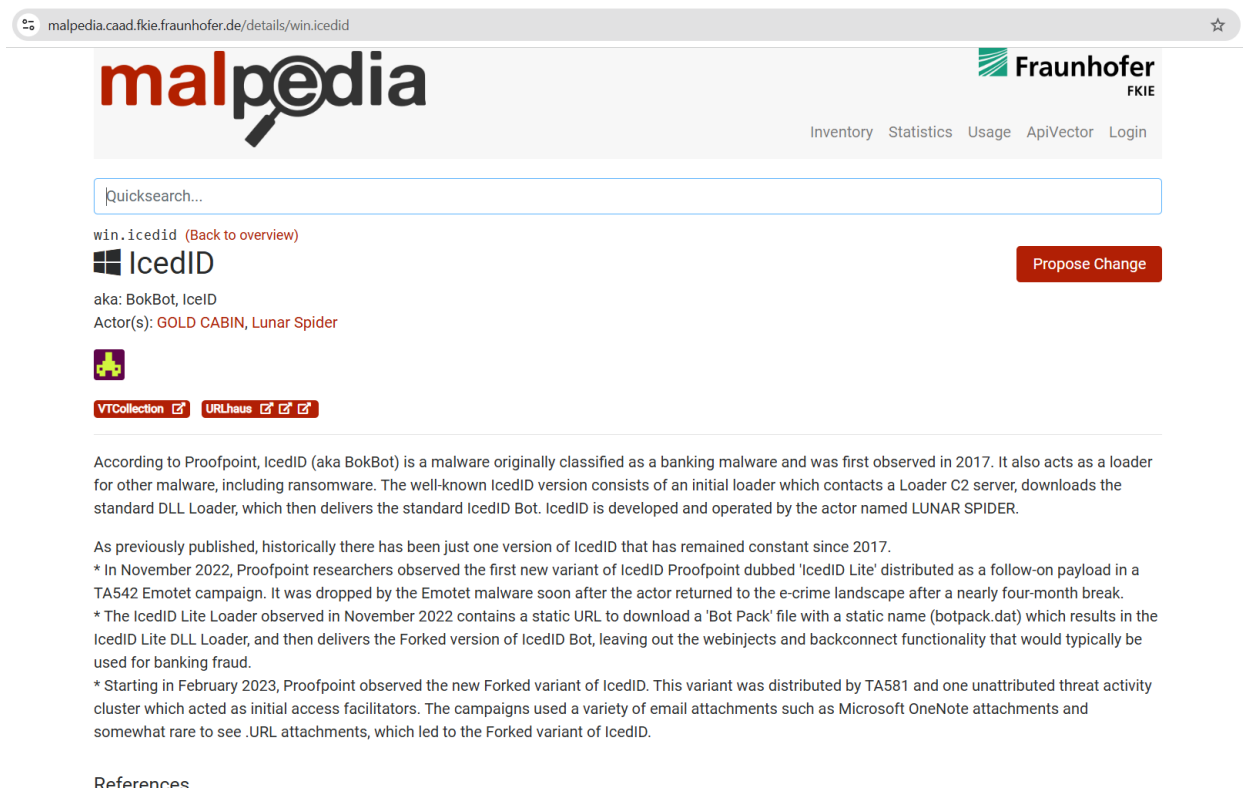
Figure 4. Registration evidence identifying NameCheap, Inc.

**Finding:** The registrar was NameCheap.

A registrar provides domain-registration services. Its appearance in WHOIS data does not establish that it participated in or knew about the malicious activity.

## 5. Threat Cluster Attribution

The IcedID malware-family entry in Malpedia was reviewed to identify threat actors associated with the family. The source listed GOLD CABIN among the associated actors.



malpedia.caad.fkie.fraunhofer.de/details/win.icedid

**malpedia** **Fraunhofer FKIE**

Inventory Statistics Usage ApiVector Login

Quicksearch...

win.icedid (Back to overview)

**IcedID**

aka: BokBot, IceID

Actor(s): GOLD CABIN, Lunar Spider

VTCollection URLhaus

According to Proofpoint, IcedID (aka BokBot) is a malware originally classified as a banking malware and was first observed in 2017. It also acts as a loader for other malware, including ransomware. The well-known IcedID version consists of an initial loader which contacts a Loader C2 server, downloads the standard DLL Loader, which then delivers the standard IcedID Bot. IcedID is developed and operated by the actor named LUNAR SPIDER.

As previously published, historically there has been just one version of IcedID that has remained constant since 2017.

- \* In November 2022, Proofpoint researchers observed the first new variant of IcedID Proofpoint dubbed 'IcedID Lite' distributed as a follow-on payload in a TA542 Emotet campaign. It was dropped by the Emotet malware soon after the actor returned to the e-crime landscape after a nearly four-month break.
- \* The IcedID Lite Loader observed in November 2022 contains a static URL to download a 'Bot Pack' file with a static name (botpack.dat) which results in the IcedID Lite DLL Loader, and then delivers the Forked version of IcedID Bot, leaving out the webinjects and backconnect functionality that would typically be used for banking fraud.
- \* Starting in February 2023, Proofpoint observed the new Forked variant of IcedID. This variant was distributed by TA581 and one unattributed threat activity cluster which acted as initial access facilitators. The campaigns used a variety of email attachments such as Microsoft OneNote attachments and somewhat rare to see .URL attachments, which led to the Forked variant of IcedID.

References

Figure 5. Malpedia IcedID entry showing associated threat actors.

**Finding:** The threat cluster requested by the investigation was GOLD CABIN.

This is an intelligence association, not proof of an individual's identity. Malware families may be shared, rented, or deployed by multiple groups.

## 6. Payload Retrieval Function

A sandbox report linked the suspicious behavior to EXCEL.EXE and detected the UrlDownloadToFile function family. The execution-specific Windows API variant was then identified.

Overview

Indicators

Mitre Attack

Network Info

Dropped Info

Processes Extra Info

Screenshots

Network Info

72.52.178.23

United States

51.68.176.178

France

15.197.192.55

United States

Dropped Info

Non malicious dropped files (14)

Processes Extra Info

Process: EXCEL.EXE

PID: 3128

Parent PID: 840

Signatures

Document exploit detected (UrlDownloadToFile)

IPs

15.197.192.55

Process: rundll32.exe

PID: 4728

Parent PID: 3128

None

Process: rundll32.exe

PID: 2916

Parent PID: 3128

None

Process: rundll32.exe

PID: 4796

Parent PID: 3128

None

Process: rundll32.exe

PID: 4436

Parent PID: 3128

None

Figure 6. Sandbox behavior identifying the payload-download API family under EXCEL.EXE.

**Finding:** The malware used URLDownloadToFileA to fetch additional payloads.

URLDownloadToFileA retrieves data from a URL and writes it to a local file. The A suffix designates the ANSI-string variant; the corresponding Unicode variant ends in W.

## Reconstructed Attack Chain

| Sequence | Observed activity                                   | Evidence                                       |
|----------|-----------------------------------------------------|------------------------------------------------|
| 1        | A malicious macro-enabled workbook reaches the user | Original filename and Office document metadata |
| 2        | The workbook is opened in Microsoft Excel           | Sandbox process context: EXCEL.EXE             |
| 3        | Embedded logic initiates payload retrieval          | UrlDownloadToFile behavioral signature         |
| 4        | Several remote domains are contacted                | Connected URL and domain relations             |
| 5        | The object 3003.gif is retrieved                    | Repeated payload filename in related URLs      |
| 6        | A second-stage malicious component is staged        | Malicious detections and sandbox relationships |

## Indicators of Compromise

| Type           | Indicator                | Context                         |
|----------------|--------------------------|---------------------------------|
| Filename       | document-1982481273.xlsm | Initial malicious document      |
| Filename       | 3003.gif                 | Disguised additional payload    |
| Malware        | IcedID                   | Malware-family classification   |
| Threat cluster | GOLD CABIN               | Threat-intelligence association |
| API            | URLDownloadToFileA       | Payload retrieval               |

Operational note: historical domains and IP addresses visible in sandbox reports should be revalidated before blocking. Expired infrastructure may later be registered or used by unrelated parties.

## MITRE ATT&CK Mapping

| Technique           | ID        | Evidence basis                                     |
|---------------------|-----------|----------------------------------------------------|
| Phishing Attachment | T1566.001 | Weaponized Excel workbook used as the initial file |

|                               |           |                                                   |
|-------------------------------|-----------|---------------------------------------------------|
| User Execution Malicious File | T1204.002 | Document execution through Microsoft Excel        |
| Ingress Tool Transfer         | T1105     | Remote retrieval of an additional payload         |
| Masquerading                  | T1036     | Payload presented with a misleading .gif filename |
| Web Protocols                 | T1071.001 | Payload delivery through web URLs                 |

## Detection Opportunities

- Alert on Office applications initiating outbound connections to newly observed or low-reputation domains.
- Detect Office processes invoking download-related APIs or spawning script interpreters and living-off-the-land binaries.
- Inspect files whose extensions do not match their content or portable executable headers.
- Hunt for repeated requests for the same payload filename across several unrelated domains.
- Correlate attachment delivery, Office execution, DNS queries, proxy requests, and newly written files in a single timeline.
- Use macro restrictions and Microsoft Attack Surface Reduction rules to reduce document-based execution risk.

## Incident Response Recommendations

| Priority   | Action                                                                                          |
|------------|-------------------------------------------------------------------------------------------------|
| Immediate  | Isolate endpoints that opened the workbook and preserve volatile evidence.                      |
| Immediate  | Quarantine the initial document and every retrieved artifact.                                   |
| High       | Search email, endpoint, DNS, proxy, and firewall telemetry for related indicators and behavior. |
| High       | Block infrastructure confirmed to remain malicious after current validation.                    |
| High       | Investigate persistence, credential access, and lateral movement before restoring the host.     |
| Preventive | Strengthen macro controls, attachment sandboxing, and endpoint behavioral detections.           |

## Answers Summary

| Investigation item                     | Verified finding         |
|----------------------------------------|--------------------------|
| File associated with the supplied hash | document-1982481273.xlsm |
| Deployed GIF filename                  | 3003.gif                 |
| Number of payload-hosting domains      | 5                        |
| Registrar used for the .com domain     | NameCheap                |
| Associated threat actor                | GOLD CABIN               |
| Function used to fetch extra payloads  | URLDownloadToFileA       |

## Conclusion

The investigation reconstructed a document-led IcedID delivery chain from a single hash. The malicious Excel workbook used multiple remote domains to retrieve a disguised object named 3003.gif, and sandbox behavior connected the retrieval to URLDownloadToFileA. Threat-intelligence enrichment associated the malware family with GOLD CABIN. The case demonstrates why analysts should pivot from a hash into metadata, relationships, infrastructure, attribution, and behavior, while keeping every conclusion tied to visible evidence and clearly stating uncertainty.